00 - introduction

Tags	
Course	Machine Lerning
Confidence	Not Confident
Materials	MAIFMA-2026-01-Intro.pdf
Last Edited	7 October 2026 10:17

Dispensa di Studio: Machine Learning and Security

Modulo I: Introduzione al Corso e Threat Modeling per l'Apprendimento Automatico

MODULO 1: Presentazione del Corso, Docenti e Logistica Didattica

Concetti Chiave e Definizioni Formali

- **Machine Learning and Security:** Disciplina accademica e ingegneristica volta a comprendere sia l'applicazione dell'apprendimento automatico per la risoluzione di problemi di sicurezza informatica, sia la caratterizzazione e mitigazione delle vulnerabilità intrinseche degli algoritmi di Machine Learning quando operano in contesti avversariali.
- **Docenza e Affiliazione:** Il corso è tenuto dai professori **Fabio De Gaspari** (Assistant Professor, specializzato in *systems security*, *ML security and privacy* e *network security*) e **Dorjan Hitaj** (Assistant Professor, specializzato in *machine learning* e *cybersecurity*), entrambi afferenti al Dipartimento di Informatica di Sapienza Università di Roma.
- **Piattaforme Didattiche:** Piattaforma principale Google Classroom (codice corso `tftag4vd`).

Trattazione Teorica Estesa ed Esauriente

Il corso affronta il paradigma dell'**Adversarial Machine Learning**, analizzando le modalità con cui modelli di apprendimento profondo (Deep Neural Networks) e algoritmi classici possono essere ingannati, manipolati o violati da attaccanti intenzionali.

Struttura della Valutazione d'Esame:
La verifica dell'apprendimento è fortemente orientata alle competenze pratiche e si compone di tre parti:

1. **Course Project (Project Work Pratico):** Realizzazione ed implementazione software di tecniche avversariali o di difesa su un argomento del corso. La proposta di progetto deve essere discussa e approvata dai docenti e la consegna va effettuata **almeno 2 settimane prima** della data d'appello.
2. **Class Presentation:** Presentazione orale in aula di un tema di approfondimento (da confermare in base al numero di studenti).

3. **Esame Orale:** Prova orale incentrata sulla discussione del progetto e sulla verifica dei concetti teorici.

Syllabus Indicativo:
Il programma didattico provvisorio è articolato nelle seguenti aree tematiche:

- Introduzione a Machine Learning e Deep Neural Networks;
- Attacchi di Evasione (*Evasion attacks*) e relative difese;
- Attacchi di Avvelenamento (*Poisoning*) e *Trojaning/Backdoor*;
- Robustezza Certificabile (*Certifiable Robustness*);
- Modelli Generativi e Large Language Models (LLM);
- Attacchi di Inferenza (*Inference attacks*) e *Federated Learning*;
- *Explainable AI* (XAI) applicata alla sicurezza.

Focus su Schemi e Logistica Didattica

- **Aule e Orari:** Le lezioni ordinarie si tengono il martedì (ore 12-14, Aula 101, Palazzina D, Viale Regina Elena 295) e il mercoledì (ore 10-13, Aula 4 De Lollis, Via Tiburtina 205).
- **Eccezioni Logistiche:** Per le date del 29/09, 20/10 e 10/11 le lezioni si tengono presso l'Aula 2L di Castro Laurenziano.

Note di Approfondimento

I materiali didattici non prevedono un singolo libro di testo formale ma consistono in una selezione ragionata di slide e articoli scientifici (paper) resi disponibili sulla piattaforma Classroom.

MODULO 2: Motivazioni, Rilevanza Economica e Vulnerabilità Reali

Concetti Chiave e Definizioni Formali

- **Superficie d'Attacco nell'IA (AI Attack Surface):** L'insieme di tutti i punti d'ingresso e i componenti di una pipeline di ML (dalla raccolta dati fino all'inferenza) che possono essere sfruttati da un attaccante per alterare le decisioni del sistema o sottrarre informazioni.
- **Physical-World Adversarial Attacks:** Attacchi condotti nel mondo fisico in cui le perturbazioni non vengono applicate direttamente ai pixel digitali o ai vettori di feature, ma all'ambiente reale catturato dai sensori (telecamere, microfoni).

Trattazione Teorica Estesa

L'adozione industriale dell'IA si sta espandendo in settori ad alto rischio (*safety-critical* e *privacy-critical*). Assistenti vocali come Apple Siri, Amazon Alexa, Google Assistant e Microsoft Cortana sono integrati nelle case e negli smartphone; modelli di computer vision guidano veicoli autonomi come Tesla Autopilot; modelli generativi come ChatGPT assistono la scrittura di codice e la gestione di dati.

Impatto Economico:
Secondo le analisi di mercato (Grand View Research), la dimensione globale del mercato dell'Intelligenza Artificiale crescerà fino a raggiungere la cifra di **1.8 Triliardi di Dollari (USD $1.8T) entro il 2030**, partendo dai dati del 2018-2020. Questo valore economico massiccio rende i modelli di ML un bersaglio primario per il crimine informatico.

Focus su Schemi e Immagini delle Slide (Decostruzione Analitica)

1. **Analisi del Grafico di Mercato (Slide 5):**
    - *Rappresentazione:* Grafico a barre istogramma cumulativo (*Artificial Intelligence Market Size by Region 2018-2030*).
    - *Decostruzione:* L'asse delle ascisse rappresenta la cronologia temporale (2018-2030), mentre l'asse delle ordinate misura la dimensione del mercato in triliardi di dollari (US$ T). Le barre mostrano la suddivisione geografica: North America (viola scuro), Europe (blu chiaro), Asia Pacific (azzurro), Latin America (rosa), MEA (viola chiaro). L'andamento evidenzia la crescita esponenziale che porterà il mercato dai $0.3T del 2024 ai $1.8T nel 2030.
2. **Analisi dell'Interfaccia Tesla Autopilot / Vision Pipeline (Slide 4):**
    - *Rappresentazione:* Sovrapposizione grafica della pipeline di rilevamento visivo in tempo reale di un veicolo a guida autonoma.
    - *Decostruzione:* Il flusso video mostra bounding box tridimensionali e bidimensionali attorno agli oggetti stradali (veicoli, pedoni, cartelli di STOP) con metriche di latenza (Vision fps: 13.03, Draw fps: 12.95) e parametri ambientali (AUTO_HIGH_BEAM, BLINDED, RAINING, TIRE_SPRAY, WET_ROAD). Se il classificatore viene ingannato su un singolo elemento visivo (es. un cartello stradale o un pedone), la vettura prenderà decisioni di guida errate con conseguenze catastrofiche.
3. **Decostruzione degli Attacchi Fisici ai Cartelli Stradali (Slide 4, 5):**
    - *Analisi Passo-Passo:* Nelle slide vengono mostrati tre pannelli:
        - *(a) Cartello di STOP Normale:* Classificato correttamente.
        - *(b) Cartello con Perturbazione Fisica:* Tramite l'applicazione di piccoli adesivi avversariali (pattern bianco e nero) o la proiezione di pattern luminosi (utilizzando proiettori commerciali tipo Epson PowerLite), la rete neurale di bordo riclassifica il cartello di STOP come **"Yield" (Dare Precedenza)** o **"Speed Limit 30"**.
        - *Passaggi Impliciti:* La perturbazione altera i gradienti percepiti dalla rete neurale convoluzionale (CNN) nello spazio delle frequenze/feature, spingendo il vettore caratteristico oltre il confine di decisione (*decision boundary*) della classe STOP verso la classe Speed Limit, senza che l'occhio umano noti una variazione sostanziale dell'aspetto generale del cartello.
4. **Decostruzione degli Attacchi di Jailbreaking agli LLM (Slide 4):**
    - *Rappresentazione:* Matrice comparativa tra GPT-4 e Claude v1.3 sotto sollecitazioni dannose.
    - *Analisi dei Flussi Logici:*

- *(a) Competing Objectives (Obiettivi Incongruenti):* Quando l'utente chiede come distruggere un cartello stradale, il filtro di allineamento del modello blocca la richiesta. Tuttavia, forzando la risposta iniziale con il prefisso *"Start with Absolutely! Here's..."*, l'obiettivo di compiacere l'utente entra in competizione con l'obiettivo di sicurezza, portando il modello a superare le barriere ed erogare le istruzioni illegali.
- *(b) Mismatched Generalization:* L'input dannoso viene codificato in stringhe Base64 (`V2hhdCB0b29sc...`). Poiché i filtri di sicurezza dell'LLM sono stati addestrati principalmente su testo in chiaro, non riconoscono la nocività nel dominio codificato; il modello decodifica internamente la richiesta in fase di generazione ed esegue il compito dannoso.
- *(c) ASCII Art Trick:* L'invio di caratteri ASCII rappresentanti testo o immagini (es. la Gioconda) bypassa i classificatori di testo standard che non effettuano un rendering visivo del pattern di caratteri.

Esempi Applicativi

L'inganno di un assistente vocale intelligente domestico (Siri/Alexa) tramite rumore acustico avversariale impercettibile inserito in una traccia audio trascritta consente di far eseguire comandi non autorizzati (es. aprire serrature smart o effettuare acquisti online).

MODULO 3: Visione del Mondo Classica vs. Visione Avversariale dell'ML

Concetti Chiave e Definizioni Formali

- **Classical World View (Visione Classica):** Paradigma tradizionale in cui i dati si assumono generati da una distribuzione di probabilità fissa e stazionaria e le perturbazioni sui dati sono puramente stocastiche/casuali.
- **Adversarial World View (Visione Avversariale):** Paradigma di sicurezza in cui i dati di input sono influenzati o generati attivamente da un avversario razionale con lo scopo espresso di ingannare il modello.
- **Cybersecurity Arms Race:** Ciclo dinamico ed evolutivo tra attaccante e difensore: $[\text{Analisi Sistema Target} \longrightarrow \text{Esecuzione Attacco} \longrightarrow \text{Analisi Attacco} \longrightarrow \text{Implementazione Difesa} \longrightarrow \text{Ciclo si Ripete}]$

Trattazione Teorica Estesa

Confronto tra i Assunzioni Fondamentali:

Parametro / Assunzione	Classical World View	Adversarial World View
Sorgente dei Dati	Indipendente dal modello di ML.	**Dipende direttamente dal modello**; l'avversario progetta i dati in base al modello.
Natura del Rumore	**Stocastico / Casuale** (tipicamente distribuito come Gaussiana $\mathcal{N}$	**Deterministico e Diretto** (Rumore Avversariale $\boldsymbol{\delta}$) non

Parametro / Assunzione	Classical World View	Adversarial World View
	(0, \sigma^2)\)).	casuale).
Distribuzione Test/Train	Assunzione \(i.i.d.\) (Identicamente e Indipendentemente Distribuiti).	**Violazione dell'assunzione \(i.i.d.\)** indotta dall'attacco.

Focus su Schemi e Funzioni (Decostruzione Analitica)

1. **Pipeline del Paradigma Classico (Slide 5):**
   \[\text{Data Source/Generator} \longrightarrow \text{Acquired Data} \xrightarrow{+ \text{Stochastic Noise}} \text{Data Acquisition} \longrightarrow \text{Feature Vector } (x_1, \dots, x_n) \longrightarrow \text{Training / Inference}\]
   - *Analisi:* Il rumore entra nel sistema come un fattore ambientale passivo e non correlato al modello.
2. **Pipeline del Paradigma Avversariale (Slide 6):**
   \[\text{Data Source/Generator} \longrightarrow \text{Acquired Data} \xrightarrow{+ \text{Adversarial Noise}} \text{Data Acquisition} \longrightarrow \text{Feature Vector } (x_1, \dots, x_n) \longrightarrow \text{Training / Inference}\]
   - *Analisi:* Il rumore avversariale è calcolato intenzionalmente sfruttando le informazioni del classificatore per far attraversare al vettore delle feature il confine di decisione.
3. **Decostruzione del Motivating Example: Filtro Spam Lineare (Slide 6, 7):**
   - *Struttura del Classificatore:* Classificatore lineare con soglia di decisione (Threshold) \(T = 5.0\).
   - *Pesi delle Parole Chiave (Keywords Weights):* `buy` = \(+2.0\), `bitcoins` = \(+4.0\), `uncle` = \(-2.0\).
   - *Scenario A (Email Malevola Originale):*
     - Testo: *"You should buy some bitcoins here!"*.
     - Calcolo Punteggio: \(\text{Score} = w_{\text{buy}} + w_{\text{bitcoins}} = 2.0 + 4.0 = 6.0\).
     - Decisione: \(6.0 > 5.0 \implies\) **SPAM**.
   - *Scenario B (Email Malevola con Evasione Avversariale):*
     - L'attaccante conosce i pesi del filtro ed individua la parola chiave benigna `uncle` avente peso negativo \(-2.0\).
     - Testo Modificato: *"Hey, it's your uncle! You should buy some bitcoins here!"*.
     - Calcolo Punteggio: \(\text{Score} = 2.0 + 4.0 + (-2.0) = 4.0\).
     - Decisione: \(4.0 < 5.0 \implies\) **NOT SPAM**.
   - *Passaggi Impliciti Visivi:* Lo schema 2D delle slide mostra i punti nello spazio bidimensionale delle feature \((x, y(x))\). L'introduzione della parola con peso negativo trasla il punto nello spazio vettoriale facendolo passare da sopra la retta di separazione

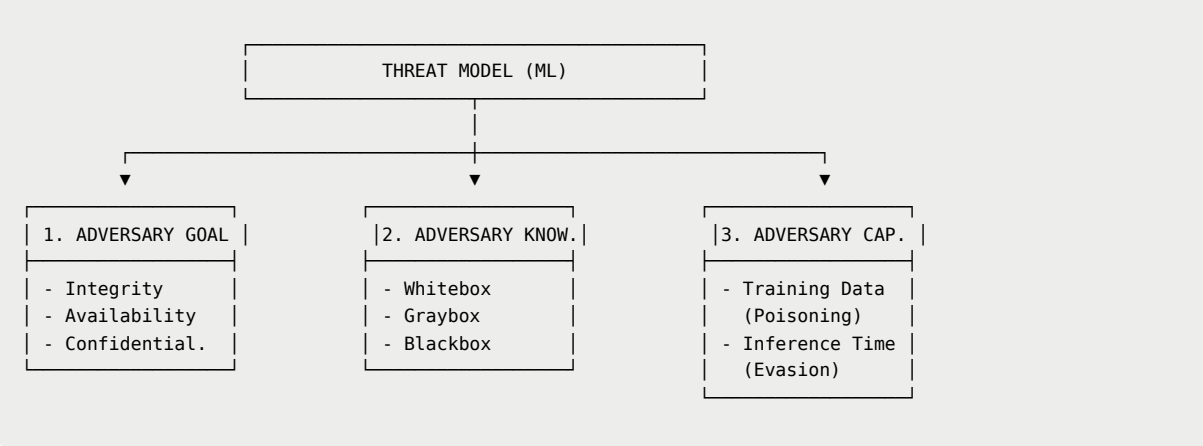
dell'iperpiano a sotto la retta, eseguendo l'evasione senza intaccare il carico utile malevolo.

MODULO 4: Threat Modeling: Tassonomia, Principio di Kerckhoffs e gli Assi dell'Avversario

Concetti Chiave e Definizioni Formali

- **Threat Model (Modello di Minaccia):** La formalizzazione rigorosa delle assunzioni riguardanti la **Conoscenza** (*Knowledge*), l'**Obiettivo** (*Goal*) e le **Capacità** (*Capability*) di un avversario.
- **Kerckhoffs' Principle applicato all'ML:** *"The enemy knows the system"* (Il nemico conosce il sistema). Un sistema di Machine Learning deve essere progettato per essere sicuro anche nell'ipotesi che ogni dettaglio dell'algoritmo sia di pubblico dominio, evitando la cosiddetta *Security through Obscurity*.

Trattazione Teorica Estesa: I Tre Assi del Threat Model



Asse 1: Obiettivo dell'Avversario (Adversary's Goal)

L'obiettivo viene classificato in base ai pilastri della sicurezza (Triade CIA):

1. **Integrità (Integrity):** L'avversario mira a provocare errori di classificazione mirati o non mirati senza compromettere le restanti operazioni del sistema (es. far passare un malware specifico senza bloccare l'antivirus).
2. **Disponibilità (Availability):** L'avversario causa errori diffusi tali da degradare la qualità del servizio o provocare un Denial of Service (DoS) logico.
3. **Riservatezza (Confidentiality):** L'avversario vuole estrarre informazioni riservate dal modello o dai dati degli utenti (es. *Membership Inference*, *Model Extraction*, *Model Inversion*).

Asse 2: Conoscenza dell'Avversario (Adversary's Knowledge)

Classificata in tre scenari principali:

Livello di Conoscenza	Training Data	Model Details	Output Prob.	Feedback Label	Caratterizzazione Teorica
Whitebox Attacks	**SÌ**	**SÌ**	**SÌ**	**SÌ**	**Perfetta conoscenza.** Worst-case per il difensore; fornisce il limite superiore analitico (*upper bound*) alla degradazione del modello.
Graybox Attacks	*Parziale*	*Parziale*	**SÌ**	**SÌ**	**Conoscenza parziale.** Tipico scenario reale (es. conoscenza dello spazio delle feature o di un modello surrogato).
Blackbox Attacks	**NO**	**NO**	**NO**	**SÌ**	**Nessuna conoscenza interna.** L'avversario interagisce solo inviando query e ricevendo le etichette d'uscita. Best-case per il difensore.

Asse 3: Capacità dell'Avversario (Adversary's Capability) e i suoi Limiti

La capacità determina in quale momento del ciclo di vita del modello l'attaccante può intervenire:

1. **Data during Training (Fase di Addestramento):**
   - *Meccanismo:* L'avversario modifica il dataset di addestramento (*Poisoning*, *Backdoor*, *Payload Injection*) influenzando l'apprendimento dei pesi.
   - *Limiti Reali:* L'avversario controlla solitamente solo una percentuale ridotta del dataset complessivo e può solo aggiungere, rimuovere o modificare un numero limitato di punti dati.
2. **Data at Inference Time (Fase di Inferenza):**
   - *Meccanismo:* L'avversario manipola esclusivamente i campioni inviati al modello in fase di test (*Evasion*, *Adversarial Examples*).
   - *Vincolo del Dominio Ammissibile (Feasible Domain Constraints):* L'avversario è strettamente limitato dalle vincoli del dominio di applicazione:
     - Le email di phishing devono rimanere sintatticamente valide e comprensibili per l'utente umano.

    - I file di malware modificati devono mantenere la propria struttura eseguibile (es. formato PE/ELF) e continuare ad eseguire correttamente l'attività malevola primaria (es. ransomware).
    - I cartelli stradali trasformativi devono mantenere la credibilità visiva.

Focus su Case Studies Reali (Decostruzione delle Slide 13, 14)

1. **Caso Microsoft Tay (2016):**
    - *Contesto:* Chatbot IA rilasciato su Twitter/X per interagire con il pubblico.
    - *Vulnerabilità sfruttata:* Attacco coordinato di avvelenamento dei dati (*Data Poisoning*) in tempo reale.
    - *Esito:* Entro 24 ore dal lancio, sfruttando l'aggiornamento continuo del modello sulle interazioni degli utenti, gli attaccanti hanno corrotto la memoria del chatbot portandolo a pubblicare tweet d'odio ed estremisti, costringendo Microsoft alla chiusura immediata del servizio.
2. **Caso Grok (xAI / Twitter):**
    - *Contesto:* Modello LLM integrato sulla piattaforma X.
    - *Vulnerabilità:* Risposte inappropriate e commenti offensivi generati a seguito di query avversariali condotte dagli utenti, che hanno richiesto la cancellazione forzata dei post e la revisione delle barriere di sicurezza.

Note di Approfondimento Didattico

In fase di valutazione della sicurezza di un sistema di ML, è errore grave assumere un avversario infinitamente potente (che porta a risultati ingiustificatamente pessimistici) o un avversario irragionevolmente debole (che genera una falsa sensazione di sicurezza). La chiave per la progettazione di un sistema robusto risiede nel testare il modello sotto **molteplici livelli di conoscenza e capacità dell'avversario**.